

Advanced Application Security: Secure Coding, Vulnerability Management & Cyber Resilience



Course-End Project





Securing the Digital Marketplace: Strengthening Security for Vulnerable Websites

Objective

To conduct a security review, identify high-risk vulnerabilities (e.g., SQLi, XSS), evaluate key features for weaknesses, simulate attacks, and implement measures to enhance website security



Problem Statement and Motivation



Real-time scenario:

During testing, an e-commerce business preparing to launch a new website identifies critical vulnerabilities, including SQL injection (SQLi) and Cross-Site Scripting (XSS). Ethical hackers simulate real-world attacks using tools like Nmap and Burp Suite to secure the platform, uncovering sensitive data exposure, broken access controls, and insecure APIs that could lead to unauthorized access and data breaches.

The findings reveal risks such as admin panel access, session hijacking, and financial fraud from issues like expired coupon validation. The development team addresses these vulnerabilities by implementing input validation, secure queries, and robust access controls to protect the platform.

After implementing fixes, the website undergoes a final security review to confirm its resilience against cyber threats.

Industry Relevance

The following tools used in this project serve specific purposes within the industry:

1. **Kali Linux:** Provides a versatile platform for penetration testing, offering pre-installed tools to identify and exploit vulnerabilities in web applications
2. **Burp Suite:** Facilitates web application security testing, enabling the detection and exploitation of high-risk vulnerabilities like SQL injection and XSS
3. **Nmap:** Performs comprehensive network scans to identify open ports, services, and potential security weaknesses in the target system
4. **SQLmap:** Automates the detection and exploitation of SQL injection vulnerabilities, assisting in database security assessments



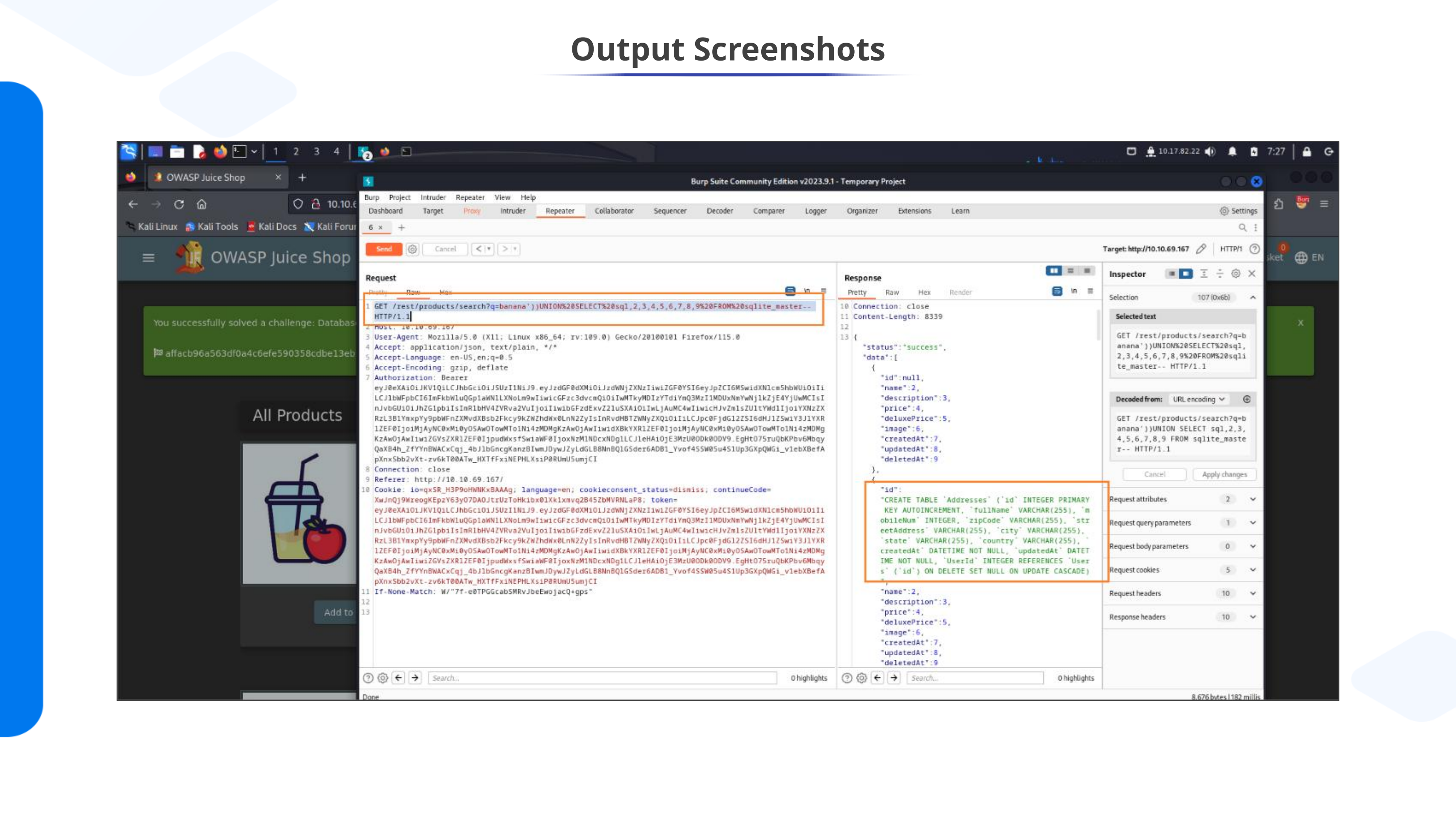
Tasks

The following tasks outline the process of enhancing website security by identifying and mitigating vulnerabilities:

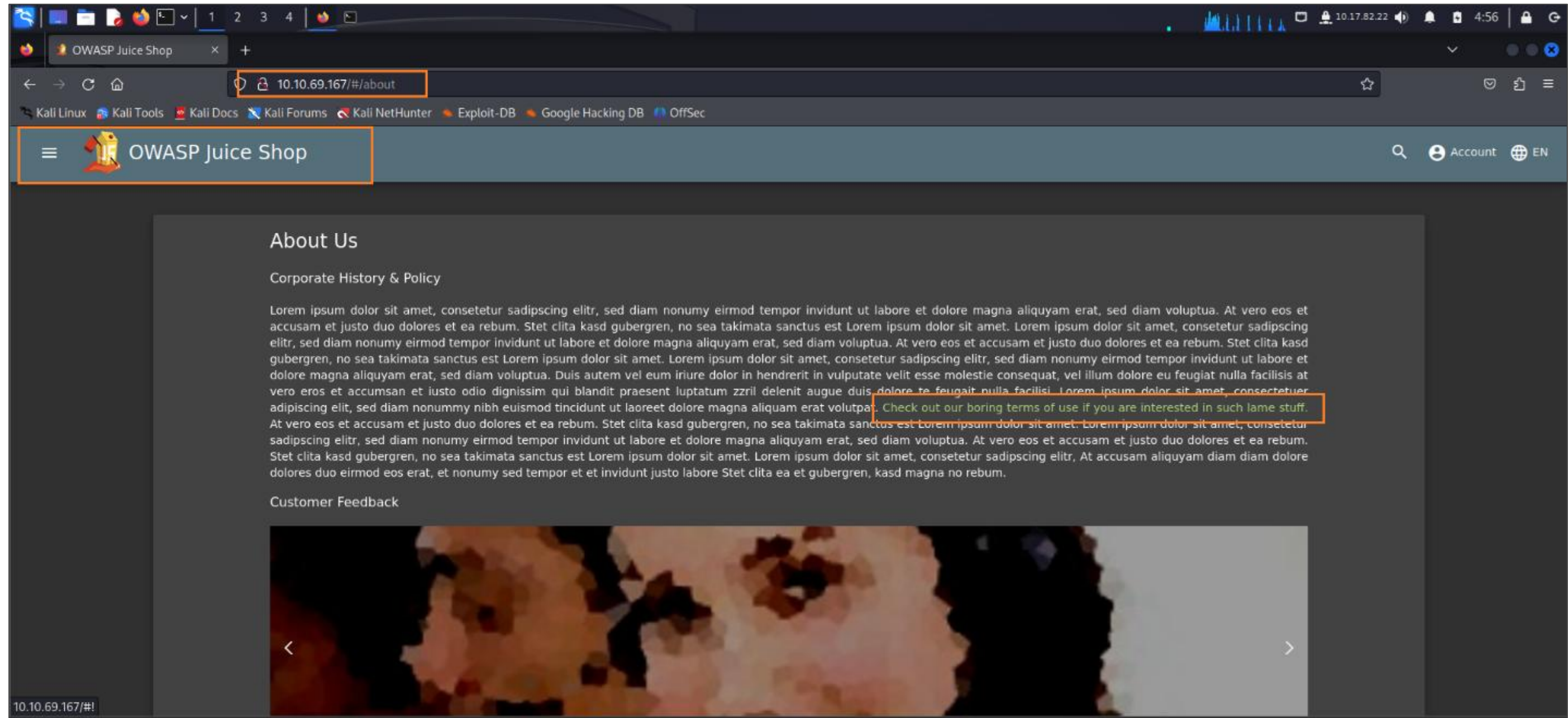
1. Conduct reconnaissance scans using tools like Nmap and Burp Suite to gather information and detect vulnerabilities
2. Test for SQL injection and XSS vulnerabilities by manipulating inputs and injecting malicious code
3. Perform access control testing to bypass restrictions and gain unauthorized access to secure sections of the website
4. Document vulnerabilities, evaluate their impact, and recommend remediation strategies to improve website security



Output Screenshots



Output Screenshots



Output Screenshots

The screenshot displays the Burp Suite Community Edition v2023.9.1 interface. The left pane shows the OWASP Juice Shop application. The main pane is divided into three sections: Request, Response, and Inspector.

Request: The request is a GET request to `/ftp/suspicious_errors.yml%2500.md` with HTTP/1.1. The request headers include Host, User-Agent, Accept, Accept-Language, Accept-Encoding, Connection, Referer, and Cookie. The request body is empty.

Response: The response is a 200 OK status with the following headers: Access-Control-Allow-Origin, X-Content-Type-Options, X-Frame-Options, Feature-Policy, Accept-Ranges, Cache-Control, Last-Modified, ETag, Content-Type, Content-Length, Vary, Date, and Connection. The response body is a YAML file containing error messages.

Inspector: The Inspector pane shows the request and response details. The response body is highlighted, showing a list of error messages.

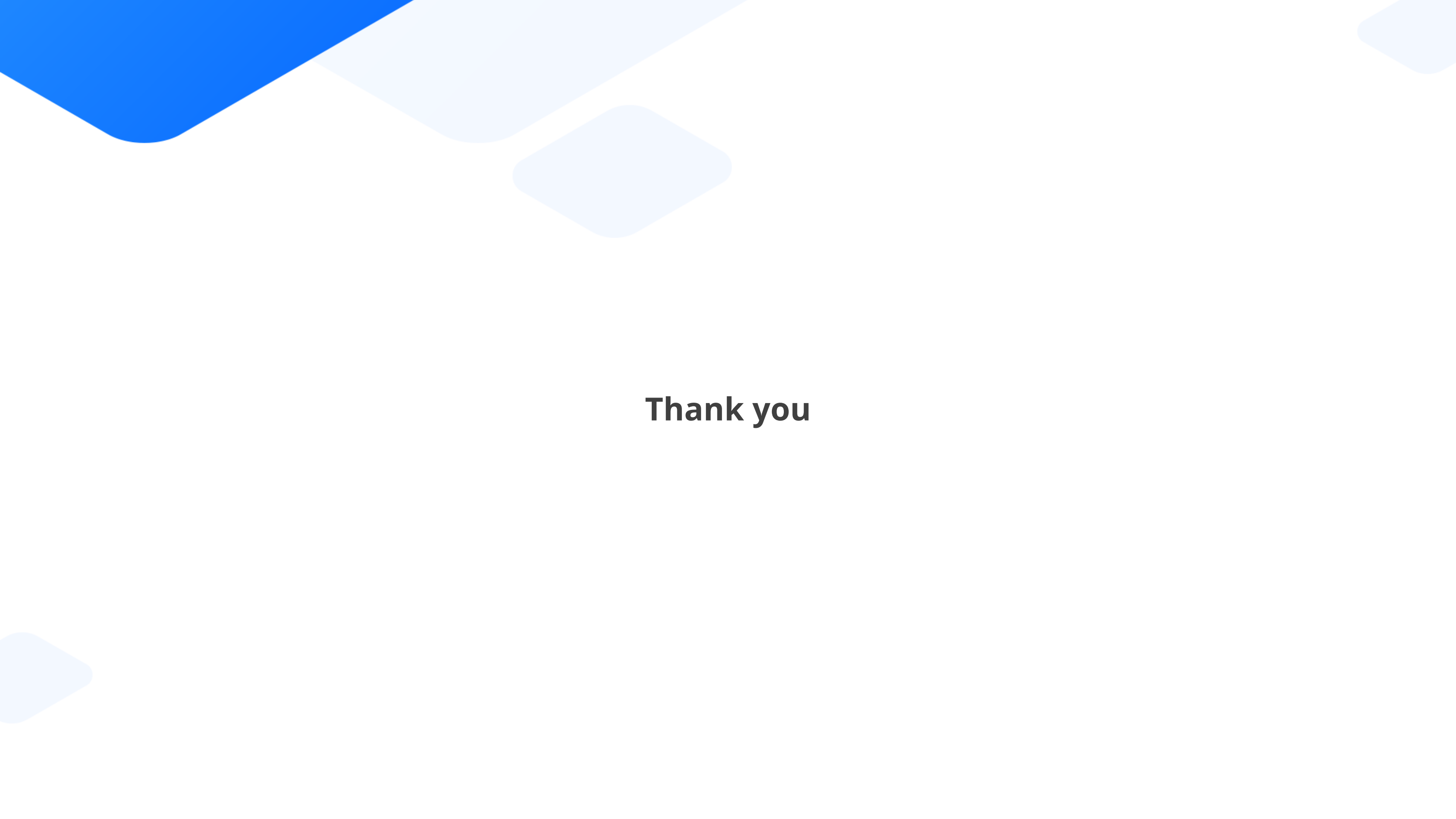
Response Body (YAML):

```
title: Suspicious error messages specific to the application
description: Detects error messages that only occur from tampering with or
  attacking the application
author: Bjoern Kimminich
logsource:
  category: application
  product: nodejs
  service: errorhandler
detection:
  keywords:
    - 'Blocked illegal activity'
    - '* with id=* does not exist'
    - 'Only * files are allowed'
    - 'File names cannot contain forward slashes'
    - 'Unrecognized target URL for redirect: *'
    - 'B2B customer complaints via file upload have been deprecated for
      security reasons'
    - 'Infinite loop detected'
    - 'Detected an entity reference loop'
  condition: keywords
level: low
```

Project References

- **Task 1:** Create a TryHackMe Account and set up the machine: Lesson_03
- **Task 2:** Perform Reconnaissance: Lesson_04
- **Task 3:** Exploit and test the vulnerabilities found: Lesson_04
- **Task 4:** Access Control Testing: Lesson_05





Thank you